

ESPRIT — École Supérieure Privée d'Ingénierie et de
Technologies

Département Cybersécurité

Mise en place d'une architecture Identity and Access Management (IAM)

Gouvernance des identités, fédération et audit de sécurité
avec Active Directory, MidPoint, Keycloak et PingCastle

Réalisé par :
Yassine Nemri

Encadré par :
M. Ali Ghorbel

Domaine de laboratoire : `cyber.local`

Durée du projet : 1 mois — Mars 2026

Année universitaire : 2025 – 2026

20 juillet 2026

Table des matières

Introduction générale	4
1 Contexte et architecture générale de la solution	5
1.1 Problématique et objectifs	5
1.2 Les trois piliers de l'architecture IAM	5
1.3 Architecture technique cible	6
1.4 Identification et justification des composants	6
1.5 Fondamentaux sur Active Directory	7
2 Mise en place et configuration d'Active Directory	8
2.1 Installation du contrôleur de domaine	8
2.2 Conception des unités d'organisation (OU)	8
2.3 Comptes de service dédiés aux intégrations	9
2.4 Groupes de sécurité	9
2.5 Synthèse	10
3 Gouvernance des identités avec MidPoint (cycle de vie JML)	11
3.1 Présentation de MidPoint	11
3.2 Architecture d'intégration	11
3.3 Modèle RBAC et catalogue de rôles	11
3.4 Scénarios du cycle de vie Joiner / Mover / Leaver	12
3.4.1 Joiner — Provisionnement automatique	12
3.4.2 Mover — Changement de département ou de rôle	13
3.4.3 Leaver — Désactivation du compte	13
3.5 Preuve de provisionnement	13
3.6 Synthèse	14
4 Fédération d'identité avec Keycloak	15
4.1 Rôle de Keycloak dans l'architecture	15
4.2 Fédération LDAP avec Active Directory	15
4.3 Synchronisation des utilisateurs	15
4.4 Groupes et mapping des rôles SOC	16
4.5 Vers une architecture SSO applicative	17
4.6 Synthèse	17
5 Audit de sécurité de l'Active Directory avec PingCastle	18
5.1 Méthodologie d'audit	18
5.2 Résultats de l'évaluation initiale	18
5.3 Analyse des risques identifiés	19
5.4 Plan de remédiation	19
5.5 Synthèse	20

6 Perspectives : vers une architecture IAM complète	21
6.1 Gestion des accès à privilèges avec HashiCorp Vault	21
6.2 Accès privilégié audité avec Teleport	21
6.3 Supervision et détection avec Wazuh	21
6.4 Vers une architecture cible étendue	21
Conclusion générale	22
Webographie	23

Table des figures

1.1	Les trois piliers de l'architecture IAM du projet	6
1.2	Architecture technique du laboratoire (traits pleins = implémenté, pointillés = perspective)	6
2.1	Arborescence des OU et des comptes du domaine <code>cyber.local</code>	8
2.2	Comptes de service <code>Keycloak Service</code> et <code>Midpoint Service</code> dans l'OU <code>ServicesAccounts</code>	9
3.1	Attributs de l'identité <code>yassine.nemri</code> provisionnée depuis la source « HR CSV Source »	13
3.2	Comptes provisionnés et liés (<i>LINKED</i>) sur la ressource <code>Active Directory</code> .	14
4.1	Utilisateurs synchronisés depuis <code>Active Directory</code> dans le royaume <code>Keycloak</code>	16
4.2	Groupes SOC répliqués dans <code>Keycloak</code>	16
5.1	Résultats de l'audit <code>PingCastle</code> du domaine <code>cyber.local</code>	18

Introduction générale

Dans le cadre de mon projet de fin de module en cybersécurité à ESPRIT, encadré par M. Ali Ghorbel, j'ai réalisé sur une période d'un mois (mars 2026) la mise en place complète d'une architecture de gestion des identités et des accès (*Identity and Access Management*, IAM). L'objectif n'était pas uniquement d'interconnecter des outils entre eux, mais de comprendre et de mettre en pratique l'ensemble de la logique IAM : cycle de vie des identités, gouvernance des accès, authentification, fédération et audit de sécurité.

L'architecture déployée repose sur le flux suivant :

Source RH (CSV) → MidPoint (IGA) → Active Directory → Keycloak (IAM/SSO) → Applications

Quatre outils open source ont été mis en œuvre :

- **Active Directory (AD)** comme annuaire d'entreprise central (source d'identité) ;
- **MidPoint** comme moteur de gouvernance des identités (IGA), responsable du cycle de vie *Joiner / Mover / Leaver* (JML) ;
- **Keycloak** comme fournisseur d'identité (IdP) fédéré à l'AD, orienté SSO ;
- **PingCastle** comme outil d'audit de sécurité de l'Active Directory.

Ce rapport présente, dans l'ordre, la démarche suivie : la conception de l'architecture, l'installation et la configuration de l'Active Directory, l'automatisation du cycle de vie des identités avec MidPoint, la fédération avec Keycloak, puis l'audit de sécurité avec PingCastle. Le dernier chapitre présente les perspectives d'extension de cette architecture vers une solution IAM complète intégrant la gestion des accès à privilèges (PAM) et la supervision de sécurité (SIEM).

Chapitre 1

Contexte et architecture générale de la solution

1.1 Problématique et objectifs

La gestion des identités dans une entreprise ne se limite pas à la création de comptes utilisateurs. Elle englobe l'ensemble du cycle de vie d'une identité — de son arrivée (*Joiner*) à son changement de poste (*Mover*) puis à son départ (*Leaver*) — ainsi que la gouvernance des accès, l'authentification fédérée et l'audit continu de la sécurité de l'annuaire.

L'objectif de ce projet est de construire, dans un environnement de laboratoire, une chaîne IAM cohérente permettant de :

- centraliser la gestion des identités et des groupes dans un annuaire Active Directory ;
- automatiser le provisionnement, la mise à jour et la désactivation des comptes à partir d'une source RH, sans intervention manuelle répétée ;
- fédérer l'authentification vers les applications via un fournisseur d'identité moderne ;
- auditer en continu la posture de sécurité de l'annuaire et proposer un plan de remédiation.

1.2 Les trois piliers de l'architecture IAM

Le projet s'articule, comme illustré en figure 1.1, autour de trois piliers complémentaires :

- **IGA (Identity Governance & Administration)** — gouvernance et automatisation du cycle de vie des identités, portée ici par MidPoint ;
- **AAM (Authentication & Access Management)** — authentification, fédération et SSO, portée ici par Keycloak, adossé à l'Active Directory ;
- **PAM (Privileged Access Management)** — gestion des accès à privilèges, traité comme perspective d'extension (chapitre 6) avec HashiCorp Vault et Teleport.

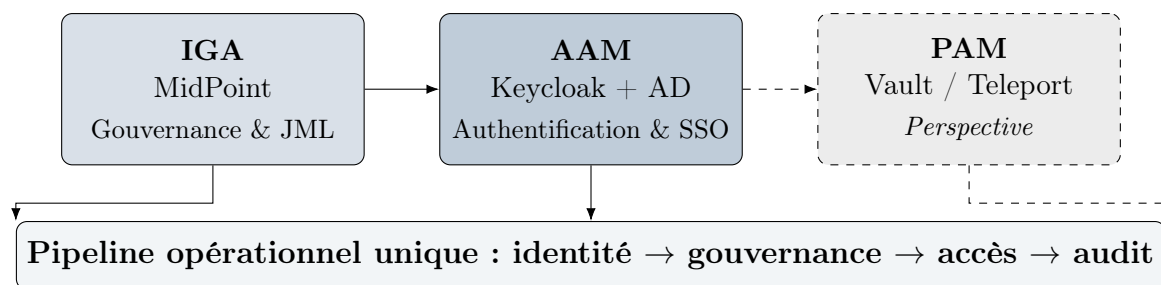


FIGURE 1.1 – Les trois piliers de l'architecture IAM du projet

1.3 Architecture technique cible

L'environnement de laboratoire a été construit sur un réseau isolé de type NAT, avec les composants principaux illustrés en figure 1.2. Le contrôleur de domaine héberge l'Active Directory (annuaire, DNS, stratégies de groupe), tandis qu'un serveur Linux dédié héberge, sous Docker, MidPoint et Keycloak. Un poste client joint au domaine permet de valider l'authentification de bout en bout.

Réseau labo NAT – 10.10.10.0/24

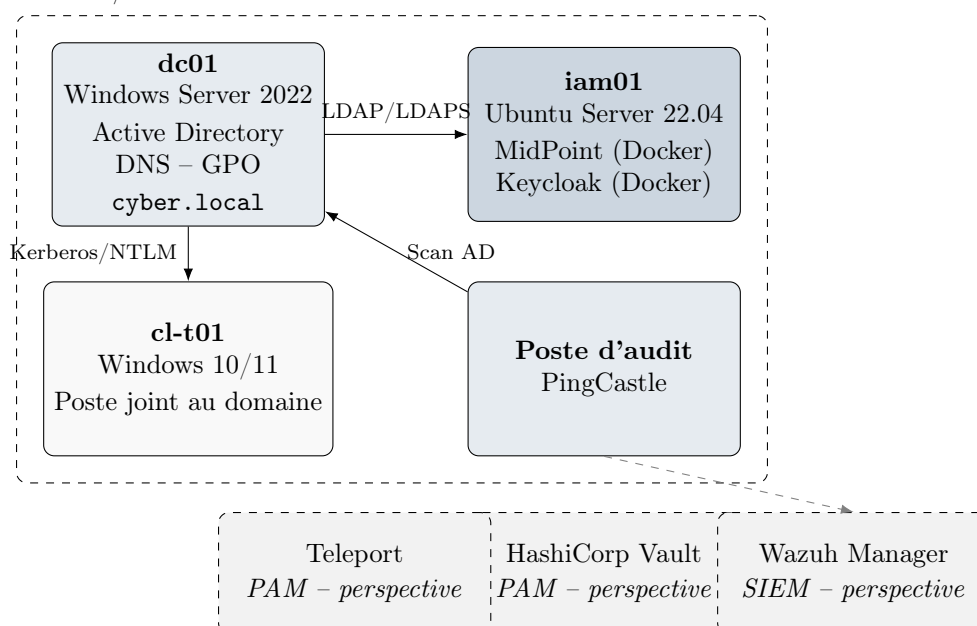


FIGURE 1.2 – Architecture technique du laboratoire (traits pleins = implémenté, pointillés = perspective)

1.4 Identification et justification des composants

Le tableau 1.1 synthétise le rôle de chaque brique de l'architecture et justifie son choix.

Composant	Rôle	Justification
Active Directory	Source d'identité / annuaire	Standard de fait en entreprise, intégration native LDAP/Kerberos, gestion centralisée des OU et des GPO
MidPoint	Plateforme IGA	Solution open source complète couvrant provisioning, cycle JML, RBAC et <i>role mining</i>
Keycloak	IdP / SSO	Fédération LDAP native vers l'AD, gestion des royaumes (<i>realms</i>), base solide pour du SSO applicatif
PingCastle	Audit de sécurité AD	Outil de référence pour l'évaluation du niveau de risque d'un domaine Active Directory

TABLE 1.1 – Composants de l'architecture IAM et justification

1.5 Fondamentaux sur Active Directory

Avant l'installation, il est utile de rappeler quelques notions clés.

Qu'est-ce qu'Active Directory ? Active Directory est le service d'annuaire de Microsoft. Il centralise dans une base de données hiérarchique l'ensemble des objets d'un réseau (utilisateurs, ordinateurs, groupes, unités d'organisation) et fournit les services d'authentification (Kerberos/NTLM) et d'autorisation nécessaires à leur gestion.

Qu'est-ce qu'un domaine ? Un domaine est une limite d'administration et de sécurité logique regroupant des objets qui partagent une même base d'annuaire et les mêmes politiques de sécurité. Dans ce projet, le domaine utilisé est `cyber.local`.

Rôle du contrôleur de domaine (DC). Le contrôleur de domaine héberge la base Active Directory, traite les requêtes d'authentification et de recherche LDAP, et réplique les modifications vers les autres contrôleurs de domaine du même domaine. Dans le laboratoire, le serveur `dc01` joue ce rôle.

Gestion centralisée. La gestion centralisée signifie que les administrateurs peuvent, depuis une console unique, créer et gérer les comptes utilisateurs, appliquer des stratégies de groupe (mots de passe, restrictions logicielles, audit), gérer l'appartenance aux groupes de sécurité, et déployer des paramètres de configuration à l'ensemble des postes joints au domaine, sans intervention locale sur chaque machine.

Chapitre 2

Mise en place et configuration d'Active Directory

2.1 Installation du contrôleur de domaine

Le serveur dc01 (Windows Server 2022) a été promu contrôleur de domaine pour une nouvelle forêt, avec le nom de domaine `cyber.local`. Cette installation inclut le rôle *Active Directory Domain Services* (AD DS) ainsi que le service DNS intégré, indispensable à la résolution des enregistrements de service (SRV) utilisés par les clients pour localiser le contrôleur de domaine.

2.2 Conception des unités d'organisation (OU)

Une arborescence d'unités d'organisation a été mise en place afin de structurer les objets par fonction et de faciliter l'application différenciée des stratégies de groupe et des délégations d'administration. La figure 2.1 présente la structure telle qu'elle apparaît dans la console *Utilisateurs et ordinateurs Active Directory*.

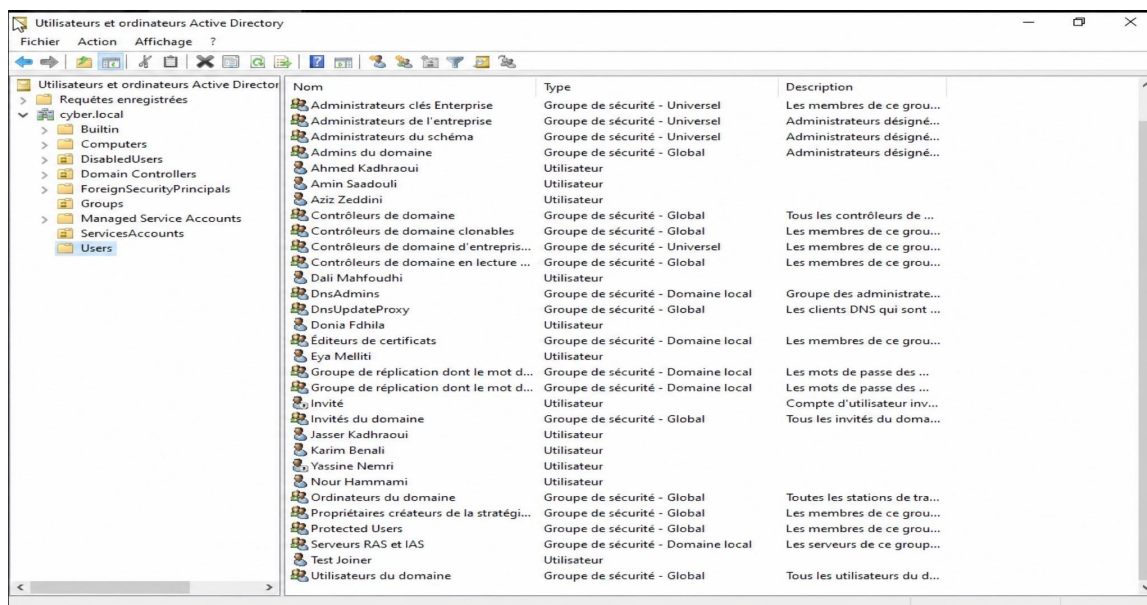


FIGURE 2.1 – Arborescence des OU et des comptes du domaine `cyber.local`

L'organisation retenue comprend notamment :

- **Users** — comptes des utilisateurs métiers provisionnés (ex. Ahmed Kadhraoui, Yassine Nemri, etc.) ;
- **DisabledUsers** — destinée à accueillir les comptes désactivés à l'issue du scénario *Leaver* ;
- **ServicesAccounts** — comptes de service dédiés aux intégrations applicatives ;
- **Groups** — groupes de sécurité métiers, dont les groupes SOC détaillés au chapitre 3 ;
- **Domain Controllers, Computers, Managed Service Accounts, Builtin, ForeignSecurityPrincipals** — objets standards de l'annuaire.

2.3 Comptes de service dédiés aux intégrations

Conformément aux bonnes pratiques (principe du moindre privilège), des comptes de service distincts ont été créés dans l'OU **ServicesAccounts** pour chacune des intégrations applicatives : **Keycloak Service** pour la fédération LDAP, et **Midpoint Service** pour le connecteur de provisioning (figure 2.2). Cette séparation évite l'utilisation d'un compte administrateur du domaine par les applications tierces et permet de restreindre les droits de chaque compte de service au strict nécessaire (par exemple, écriture limitée à l'OU **Users** pour le compte **MidPoint**).

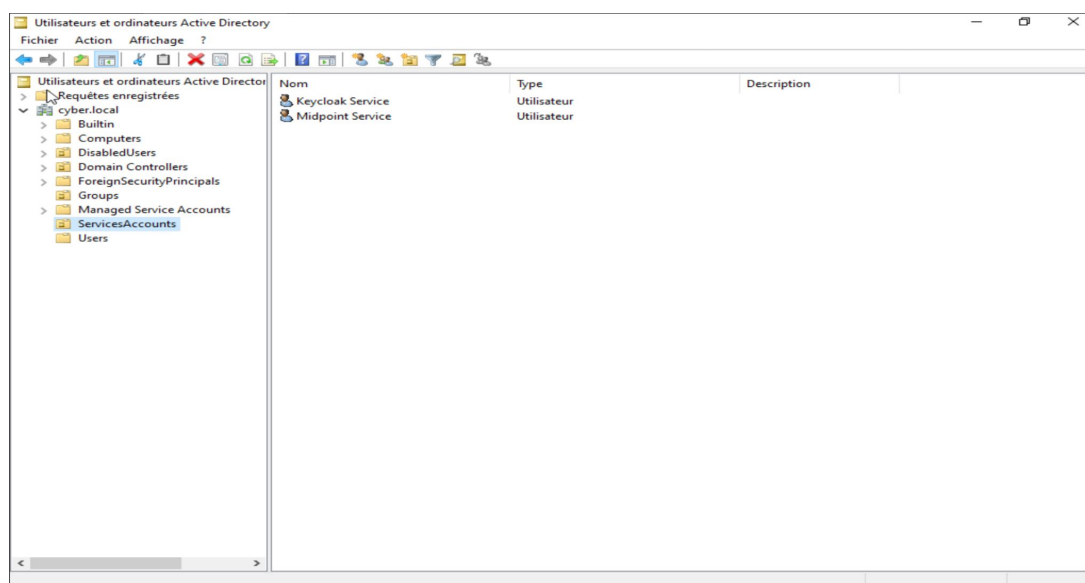


FIGURE 2.2 – Comptes de service Keycloak Service et Midpoint Service dans l'OU **ServicesAccounts**

2.4 Groupes de sécurité

Outre les groupes intégrés de l'annuaire (Admins du domaine, Contrôleurs de domaine, DnsAdmins, Éditeurs de certificats, etc., visibles en figure 2.1), des groupes de sécurité métiers dédiés au cas d'usage SOC (*Security Operations Center*) ont été créés dans l'OU **Groups**. Ces groupes, préfixés **GG_SOC_**, servent de pivot entre le modèle de rôles défini dans **MidPoint** et les permissions applicatives fédérées via **Keycloak** (détaillés au chapitre 3).

2.5 Synthèse

Cette première phase a permis de mettre en place un annuaire structuré, avec une séparation claire entre comptes utilisateurs, comptes de service et groupes de sécurité — prérequis indispensable avant de pouvoir automatiser le provisionnement via MidPoint.

Chapitre 3

Gouvernance des identités avec MidPoint (cycle de vie JML)

3.1 Présentation de MidPoint

MidPoint est une plateforme open source de gouvernance et d'administration des identités (IGA). Il agit comme périmètre de sécurité autour de l'identité, en assurant notamment la gouvernance des identités, l'audit et le reporting de sécurité, la gestion de la structure organisationnelle, la gestion des identifiants, l'approbation des demandes d'accès et la gestion des droits (*entitlements*).

3.2 Architecture d'intégration

L'intégration suit le schéma décrit en introduction : une source RH au format CSV alimente MidPoint, qui provisionne ensuite automatiquement les comptes dans l'Active Directory via un connecteur LDAP. Deux ressources ont donc été configurées dans MidPoint :

1. **Ressource CSV (« HR CSV Source »)** — représente le système RH. Le champ `employeeId` est défini comme identifiant primaire, et une tâche de synchronisation *live sync* interroge la source à intervalle régulier pour détecter les nouvelles lignes ou les modifications.
2. **Ressource LDAP (Active Directory)** — pointe vers le contrôleur de domaine `dc01.cyber.local` et utilise le connecteur LDAP de MidPoint (`com.evolveum.polygon.connectors.ldaps`) en LDAPS (port 636). L'authentification vers l'annuaire se fait avec le compte de service `Midpoint Service`, dont les droits d'écriture sont restreints à l'OU `Users`.

Le schéma d'attributs utilisé pour la source RH, tel qu'il apparaît dans les objets « shadow » de MidPoint, est le suivant :

Listing 3.1 – Structure de la source RH (CSV) utilisée par MidPoint

```
employeeId,firstName,lastName,email,department,jobTitle,status,adGroup  
EMP008,Yassine,Nemri,yassine.nemri@cyber.local,SOC,SOC Engineer,active,  
GG_SOC_Engineer
```

3.3 Modèle RBAC et catalogue de rôles

Le cas d'usage retenu pour peupler l'annuaire simule une équipe SOC (Security Operations Center). Six rôles métiers ont été définis, chacun associé à un groupe de sécurité AD

dédié, comme indiqué dans le tableau 3.1. Cette approche a été amorcée en s'appuyant sur la fonctionnalité de *Role Mining* de MidPoint, qui permet de découvrir des rôles à partir des appartenances aux groupes AD existants, afin de construire un catalogue de rôles cohérent.

Rôle métier	Groupe AD associé
Analyste SOC niveau 1	GG_SOC_Analyst_L1
Analyste SOC niveau 2	GG_SOC_Analyst_L2
Ingénieur SOC	GG_SOC_Engineer
Manager SOC	GG_SOC_Manager
Supervision SOC	GG_SOC_Monitoring
Threat Intelligence SOC	GG_SOC_Threat_intel

TABLE 3.1 – Modèle RBAC : correspondance rôle métier → groupe de sécurité AD

L'attribut `department` (par exemple « SOC ») et l'attribut `adGroup` de la source RH permettent à MidPoint de calculer automatiquement les appartenances aux groupes lors du provisionnement.

3.4 Scénarios du cycle de vie Joiner / Mover / Leaver

3.4.1 Joiner — Provisionnement automatique

Lorsqu'une nouvelle ligne apparaît dans la source CSV avec le statut `active`, MidPoint crée automatiquement le compte correspondant dans l'Active Directory, calcule l'appartenance aux groupes à partir du département et du poste, puis synchronise les attributs métiers.

La figure 3.1 illustre ce mécanisme pour l'utilisateur `yassine.nemri` (matricule `EMP008`) : l'objet *shadow* MidPoint reflète fidèlement les attributs importés depuis la source RH (nom, prénom, département « SOC », poste « SOC Engineer », groupe AD cible `GG_SOC_Engineer`, statut `active`) et les propage vers le compte Active Directory correspondant.

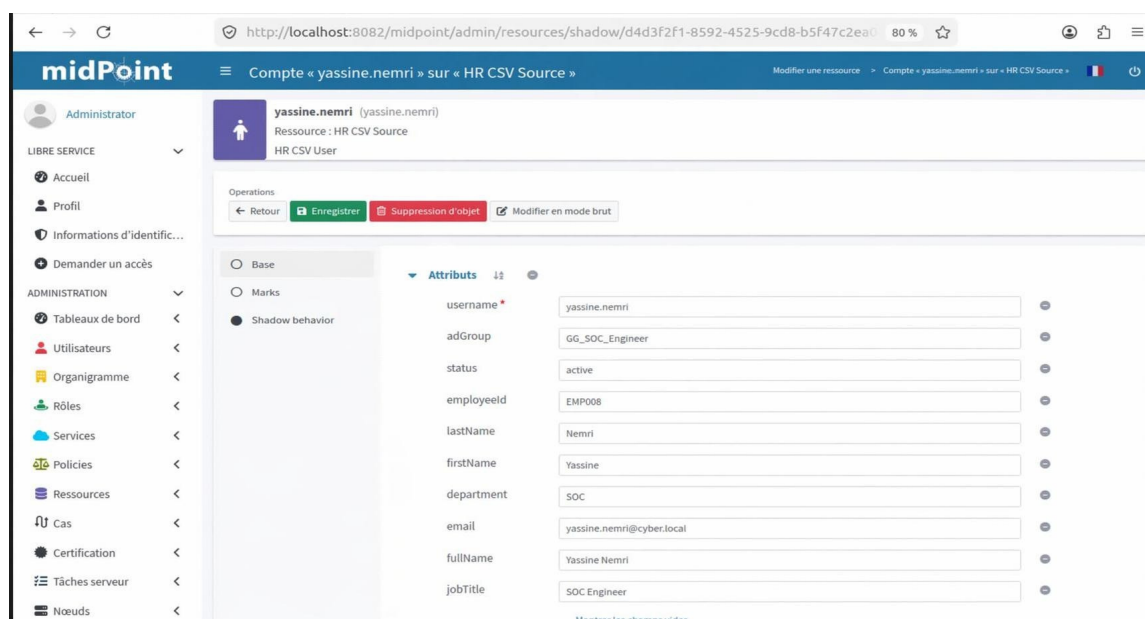


FIGURE 3.1 – Attributs de l'identité `yassine.nemri` provisionnée depuis la source « HR CSV Source »

3.4.2 Mover — Changement de département ou de rôle

Lorsqu'un changement de département est détecté dans la source RH pour un utilisateur existant, MidPoint recalcule les affectations de rôles associées et met à jour en conséquence les appartenances aux groupes AD : retrait des groupes qui ne sont plus applicables, ajout des nouveaux groupes correspondant au nouveau département ou au nouveau poste. Ce mécanisme repose sur le même moteur de mapping que le scénario Joiner, appliqué de façon différentielle.

3.4.3 Leaver — Désactivation du compte

Lorsque le statut d'un utilisateur passe à `inactive` dans la source RH, MidPoint désactive automatiquement le compte AD correspondant, retire l'ensemble de ses appartenances aux groupes de sécurité, et marque le compte pour une revue après un délai de rétention (90 jours) avant suppression définitive — l'OU `DisabledUsers` de l'annuaire est prévue pour accueillir ces comptes en phase de rétention.

Un compte de test (`Test Joiner`), visible dans l'OU `Users` de l'annuaire, a été utilisé pour valider ces trois scénarios avant leur application aux comptes réels.

3.5 Preuve de provisionnement

La figure 3.2 présente la liste des comptes gérés par MidPoint sur la ressource « HR CSV User ». Les neuf comptes provisionnés (`ahmed.kadhraoui`, `amin.saadouli`, `aziz.zeddini`, `dali.mahfoudhi`, `donia.fdhila`, `eya.melliti`, `jasser.kadhraoui`, `karim.benali`, `yassine.nemri`) apparaissent avec le statut **LINKED**, confirmant que chaque identité de la source RH est correctement corrélée à son compte Active Directory correspondant.

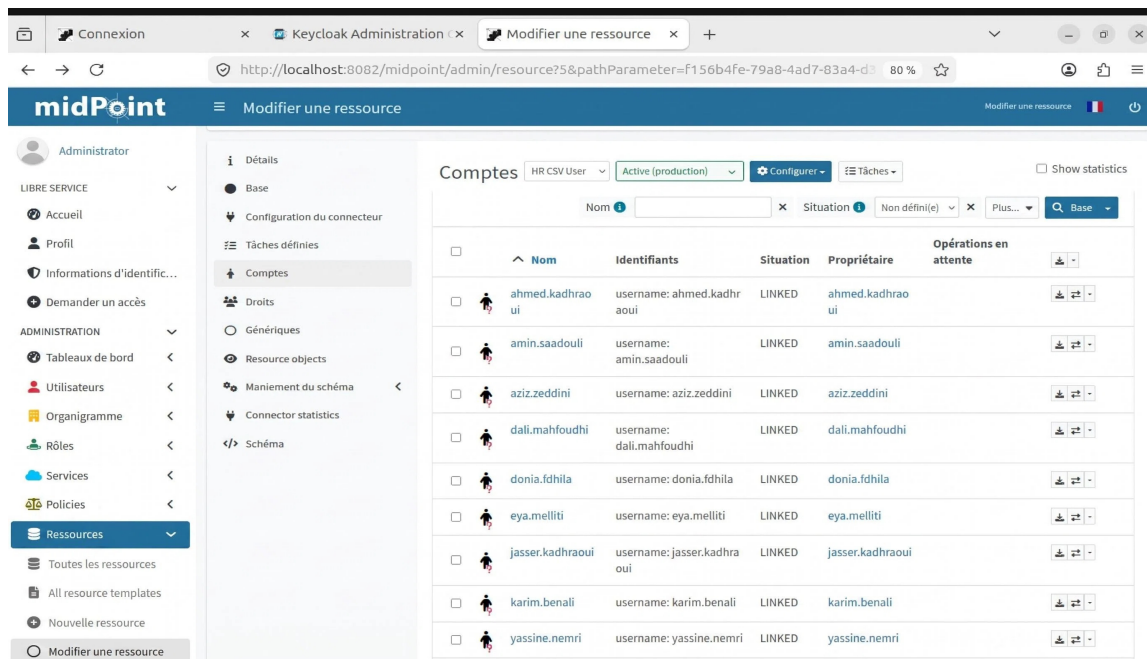


FIGURE 3.2 – Comptes provisionnés et liés (*LINKED*) sur la ressource Active Directory

3.6 Synthèse

MidPoint assure ainsi le rôle central de moteur de gouvernance : il transforme une simple ligne CSV en une identité complète, dotée d'un compte Active Directory, d'attributs métiers et d'appartenances aux groupes cohérentes avec le rôle occupé, sans intervention manuelle de l'administrateur.

Chapitre 4

Fédération d'identité avec Keycloak

4.1 Rôle de Keycloak dans l'architecture

Keycloak a été intégré comme couche de fournisseur d'identité (IdP) moderne, positionnée entre l'Active Directory et les applications. Son rôle est de permettre une authentification unique (SSO) des utilisateurs à partir de leurs informations d'identification AD, sans dupliquer la gestion des mots de passe au niveau applicatif.

4.2 Fédération LDAP avec Active Directory

Un fournisseur de fédération d'utilisateurs LDAP a été configuré dans le royaume (*realm*) Keycloak, pointant vers le domaine `cyber.local`, en s'appuyant sur le compte de service Keycloak `Service` créé dans l'OU `ServicesAccounts` (chapitre 2). Cette fédération permet à Keycloak de déléguer la vérification des identifiants (*bind LDAP*) directement à l'Active Directory, tout en synchronisant localement les attributs des utilisateurs.

4.3 Synchronisation des utilisateurs

La figure 4.1 montre la liste des utilisateurs présents dans Keycloak après synchronisation avec l'annuaire. On y retrouve l'ensemble des comptes provisionnés par MidPoint (`ahmed.kadhraoui`, `amin.saadouli`, `aziz.zeddini`, `dali.mahfoudhi`, `donia.fdhila`, `eya.melliti`, `jasser.kadhraoui`, `karim.benali`), avec leurs adresses e-mail au format `prenom.nom@cyber.local`. Le compte `invité`, désactivé côté Active Directory, apparaît correctement avec le statut **Disabled** dans Keycloak, ce qui valide la bonne propagation de l'état des comptes entre les deux systèmes.

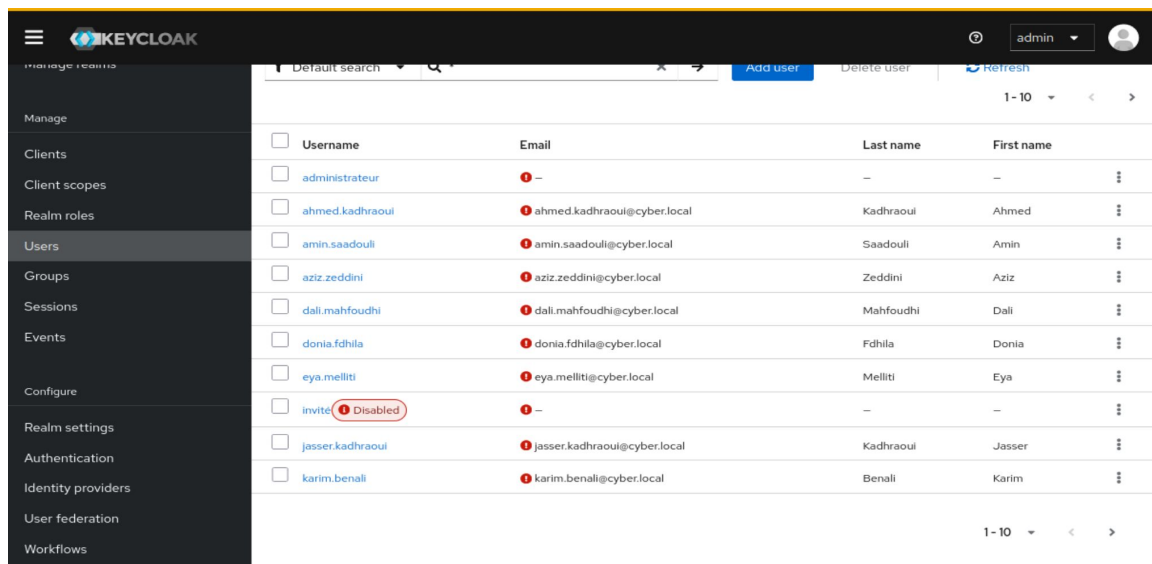


FIGURE 4.1 – Utilisateurs synchronisés depuis Active Directory dans le royaume Keycloak

*Remarque sécurité : la bannière affichée dans la console Keycloak signale que le compte **admin** utilisé est un compte administrateur temporaire, et recommande la création d'un compte administrateur permanent puis la suppression du compte temporaire — action identifiée comme point d'amélioration dans le plan de durcissement (chapitre 5).*

4.4 Groupes et mapping des rôles SOC

Les six groupes métiers **GG_SOC_*** définis dans le modèle RBAC de MidPoint (tableau 3.1) sont répliqués côté Keycloak sous forme de groupes (figure 4.2) : **GG_SOC_Analyst_L1**, **GG_SOC_Analyst_L2**, **GG_SOC_Engineer**, **GG_SOC_Manager**, **GG_SOC_Monitoring** et **GG_SOC_Threat_intel**. Cette correspondance directe entre groupes AD et groupes Keycloak permet, via un *group mapper* LDAP, de faire hériter automatiquement à chaque utilisateur fédéré les rôles applicatifs correspondant à son groupe AD — posant ainsi les bases d'une gestion des accès basée sur les rôles (RBAC) au niveau applicatif.

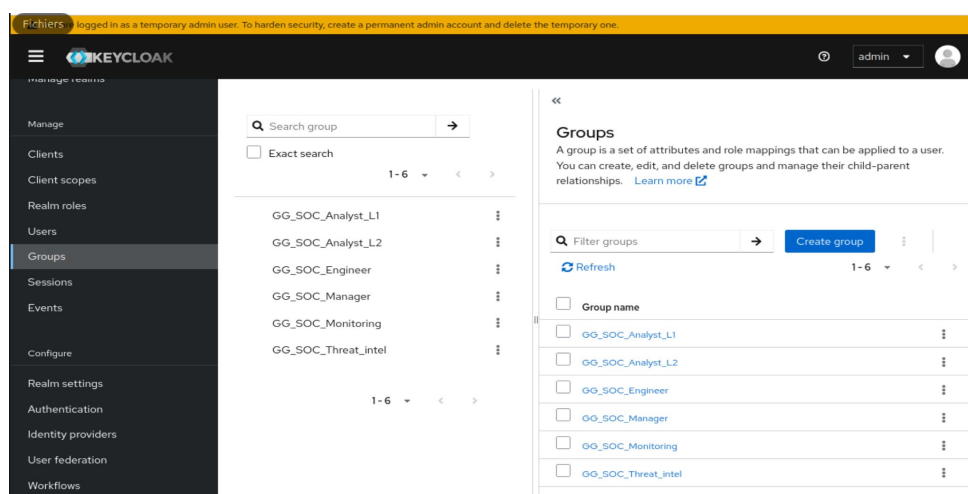


FIGURE 4.2 – Groupes SOC répliqués dans Keycloak

4.5 Vers une architecture SSO applicative

Cette fédération constitue le socle d'une architecture SSO : toute application configurée comme client Keycloak (via OpenID Connect ou SAML) pourra déléguer son authentification au royaume fédéré à l'AD, et récupérer les groupes/rôles de l'utilisateur pour appliquer un contrôle d'accès fin, sans avoir à gérer elle-même les mots de passe.

4.6 Synthèse

Keycloak referme la boucle du pipeline IAM : les identités créées par MidPoint et stockées dans l'Active Directory deviennent, via la fédération LDAP, directement exploitables pour l'authentification et l'autorisation applicatives.

Chapitre 5

Audit de sécurité de l'Active Directory avec PingCastle

5.1 Méthodologie d'audit

L'audit de sécurité d'un Active Directory consiste à collecter des informations sur les attributs et objets de l'annuaire, à analyser les journaux d'activité et les configurations, à identifier d'éventuels écarts de sécurité ou de conformité, et à produire un rapport sur l'état de santé général du domaine. PingCastle a été utilisé pour automatiser cette démarche : l'outil scanne le domaine `cyber.local` et calcule un score de risque selon quatre indicateurs indépendants.

5.2 Résultats de l'évaluation initiale

La figure 5.1 présente le tableau de bord obtenu lors de l'évaluation initiale du domaine `cyber.local`.

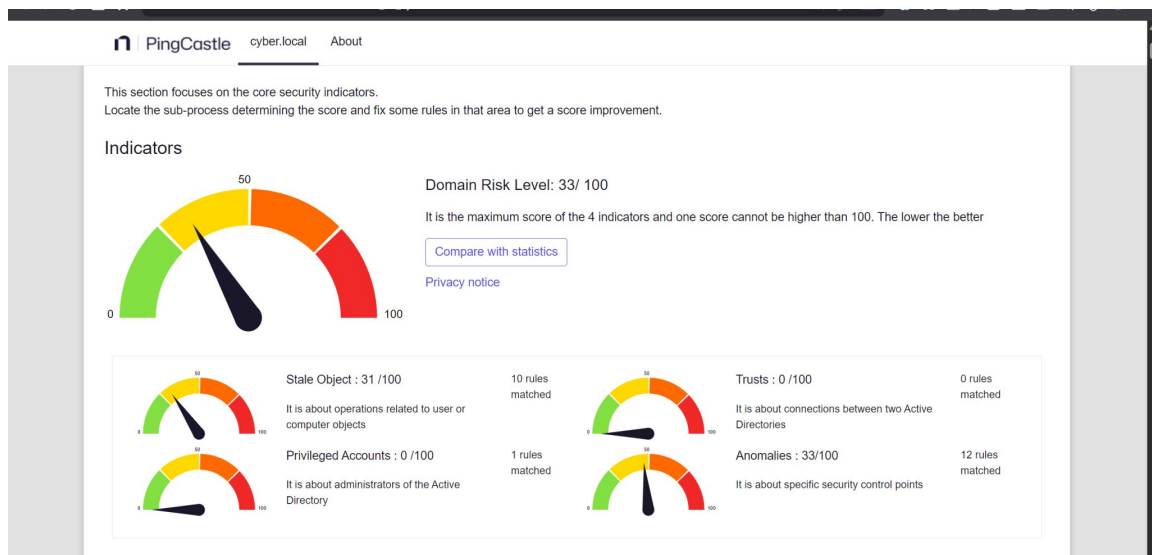


FIGURE 5.1 – Résultats de l'audit PingCastle du domaine `cyber.local`

Le niveau de risque global du domaine (*Domain Risk Level*) — correspondant au maximum des quatre indicateurs — s'établit à **33/100**, ce qui place le domaine dans la zone orange (score compris entre 10 et 30 : règles à examiner avec attention). Le détail par indicateur est résumé dans le tableau 5.1.

Indicateur	Score	Règles déclenchées	Portée
Stale Objects (objets obsolètes)	31/100	10	Comptes utilisateurs/or
Privileged Accounts (comptes à privilèges)	0/100	1	Administration de l'AD
Trusts (relations d'approbation)	0/100	0	Connexions inter-domain
Anomalies	33/100	12	Points de contrôle de sé

TABLE 5.1 – Détail des quatre indicateurs PingCastle

5.3 Analyse des risques identifiés

- **Stale Objects (31/100, 10 règles)** — cet indicateur, le plus élevé après *Anomalies*, signale la présence d'objets utilisateurs ou ordinateurs inactifs ou obsolètes dans l'annuaire. Ce résultat est cohérent avec un environnement de laboratoire récemment peuplé, dans lequel plusieurs comptes de test (par exemple **Test Joiner**) et l'ancienneté de certains attributs n'ont pas encore fait l'objet d'un nettoyage périodique.
- **Anomalies (33/100, 12 règles)** — cet indicateur regroupe des points de contrôle de sécurité variés (protocoles d'authentification obsolètes, configuration de la réplique, etc.). C'est l'indicateur qui détermine le niveau de risque global du domaine et qui doit être traité en priorité.
- **Privileged Accounts (0/100, 1 règle)** — score très faible, ce qui indique une gestion globalement saine des comptes à privilèges (peu de comptes administrateurs superflus détectés), avec toutefois une règle mineure à corriger.
- **Trusts (0/100, 0 règle)** — aucun risque, ce qui s'explique simplement par l'absence de relations d'approbation inter-domaines dans ce laboratoire mono-domaine.

5.4 Plan de remédiation

À partir de ces résultats, un plan de remédiation priorisé a été défini, en cohérence avec les indicateurs les plus élevés (Anomalies et Stale Objects) :

Action de remédiation	Priorité
Désactiver NTLMv1 et n'autoriser que NTLMv2	Haute
Désactiver les protocoles obsolètes (SMBv1, RC4 pour Kerberos)	Haute
Activer les stratégies d'audit avancées (connexion de compte, utilisation des privilèges, modifications de l'annuaire) via GPO	Haute
Nettoyer les objets utilisateurs/ordinateurs obsolètes (<i>Stale Objects</i>)	Moyenne
Définir une stratégie de mot de passe affinée (<i>Fine-Grained Password Policy</i>) pour les comptes de l'OU Privilégiés (16 caractères minimum, complexité renforcée)	Moyenne
Revoir et corriger la règle restante sur les comptes à privilèges	Basse

TABLE 5.2 – Plan de remédiation priorisé, issu de l'audit PingCastle

5.5 Synthèse

Ce premier audit constitue une base de référence (*baseline*) pour le suivi de la posture de sécurité de l'annuaire. Le plan de remédiation ci-dessus a été formalisé à l'issue de ce scan initial ; sa mise en œuvre complète et le nouveau scan de comparaison post-remédiation constituent la suite logique de ce travail, mentionnée dans les perspectives du chapitre suivant. Cette étape confirme qu'en matière d'IAM, provisionner des identités n'est qu'une partie du travail : encore faut-il s'assurer que l'infrastructure d'identité elle-même reste sécurisée et auditable.

Chapitre 6

Perspectives : vers une architecture IAM complète

L'architecture réalisée couvre les piliers IGA (MidPoint) et AAM (Keycloak + Active Directory), ainsi que l'audit de sécurité (PingCastle). Le cahier des charges initial du laboratoire prévoyait également l'intégration d'un pilier PAM et d'une brique de supervision de sécurité (SIEM), qui n'ont pas pu être finalisés dans le délai d'un mois imparti au projet et constituent naturellement les prochaines étapes.

6.1 Gestion des accès à privilèges avec HashiCorp Vault

HashiCorp Vault est prévu pour centraliser la gestion des secrets (mots de passe, clés, certificats) et pour fournir des identifiants dynamiques à durée de vie limitée aux comptes de service déjà créés dans l'OU `ServicesAccounts` (`Keycloak Service`, `Midpoint Service`), réduisant ainsi le risque lié à des secrets statiques et de longue durée.

6.2 Accès privilégié audité avec Teleport

Teleport est envisagé comme passerelle d'accès privilégié (PAM), afin de tracer, enregistrer et restreindre dans le temps les sessions d'administration vers le contrôleur de domaine `dc01` et le serveur `iam01`, en s'appuyant sur les groupes à privilèges déjà identifiés lors de l'audit PingCastle.

6.3 Supervision et détection avec Wazuh

Un serveur Wazuh Manager est prévu pour la collecte et la corrélation des journaux d'événements de sécurité (notamment les événements d'audit de l'annuaire évoqués au chapitre 5 : création, modification ou suppression d'objets de l'annuaire), afin de transformer l'audit ponctuel réalisé avec PingCastle en une détection continue des anomalies.

6.4 Vers une architecture cible étendue

L'intégration de ces trois briques permettrait de compléter le pipeline opérationnel amorcé dans ce projet (figure 1.2) et de couvrir l'ensemble des trois piliers IGA / AAM / PAM, tout en bouclant la boucle audit → remédiation → détection continue.

Conclusion générale

Ce projet m'a permis de construire, de bout en bout, une architecture IAM fonctionnelle reliant une source RH, un moteur de gouvernance des identités, un annuaire d'entreprise et un fournisseur d'identité fédéré, puis d'en évaluer la posture de sécurité. Au-delà de la mise en œuvre technique, ce travail m'a surtout permis de comprendre que l'IAM ne se résume pas à l'authentification : il s'agit avant tout d'une discipline transverse couvrant le cycle de vie des identités, la gouvernance des accès, la fédération, l'automatisation et l'auditabilité continue.

L'automatisation du cycle de vie Joiner / Mover / Leaver avec MidPoint, la fédération d'authentification avec Keycloak et l'audit initial réalisé avec PingCastle constituent une base solide, que les perspectives d'intégration d'un volet PAM (Vault, Teleport) et d'un volet SIEM (Wazuh) permettront de compléter afin d'obtenir une architecture IAM d'entreprise complète.

Cette expérience pratique a renforcé mes compétences techniques en IAM, IGA, sécurité Active Directory et fédération d'identité, et m'a donné envie d'approfondir davantage ces sujets dans la suite de mon parcours en cybersécurité.

Webographie

- Documentation officielle MidPoint — Evolveum, <https://docs.evolveum.com>
- Documentation officielle Keycloak, <https://www.keycloak.org/documentation>
- Documentation Microsoft — Active Directory Domain Services, <https://learn.microsoft.com/windows-server/identity/ad-ds/>
- Documentation officielle PingCastle, <https://www.pingcastle.com>
- Documentation HashiCorp Vault, <https://developer.hashicorp.com/vault>
- Documentation Teleport, <https://goteleport.com/docs/>
- Documentation Wazuh, <https://documentation.wazuh.com>